Assignment Proposal

Securing an Industrial Learning Factory (Festo CPLab)

Context

Fontys operates a **Festo Smart Industry Machine (CPLab)** that represents a modern **Industry 4.0 production line**, including:

- Siemens S71500 PLCs and HMI panels
- Profinet I/O
- OPC UA, MQTT
- MES, Webshop, database connections
- Industrial PCs
- Ethernet switches
- Collaborative robot (UR3e)
- Web interfaces and remote access possibilities

The factory is **functionally operational**, but not yet designed according to **state of the art industrial cybersecurity principles**.

As cybersecurity engineers specialized in **Operational Technology (OT)**, your task is to **assess, redesign and harden** this system.

Assignment Objective

Design a **secure by design architecture** for the Festo factory that:

1. Protects availability, integrity and confidentiality
2. Is aligned with **modern industrial cybersecurity standards and regulations**
3. Remains **operational, maintainable and realistic for an educational factory**

Learning Outcomes

After completing this assignment, students will be able to:

- Analyze an OT/ITconverged industrial system
- Model industrial networks and data flows
- Perform a structured **risk assessment**

- Apply international **industrial cybersecurity standards**
- Design segmented networks using VLANs, firewalls and DMZs
- Secure industrial protocols (Profinet, OPC UA, MQTT)
- Propose securityrelevant hardware and configurations
- Justify design decisions professionally

Assignment Description

Phase 1 – Description of the Current State (ASIS)

Document the factory **as it currently exists**.

1. System Inventory

Create a structured inventory of:

- PLCs (type, firmware, IP addressing)
- HMIs
- Industrial PCs
- Switches
- Robots
- Sensors/actuators with IP capabilities
- Servers, MES, databases
- Engineering stations

Deliverable:
Asset list table including function, protocol usage and network location

---

2. Communication Mapping

Document **who communicates with whom**, and **how**.

For each connection:

- Source → Destination
- Protocol (Profinet, OPC UA, MQTT, HTTP, etc.)
- Port numbers
- Direction (client/server, cyclic/acyclic)

- Purpose (control, monitoring, diagnostics, data analytics)

Deliverables:

- **Network diagram (logical)**
- **Data flow diagram**
- **Protocol matrix**

---

3. Trust Zones and Current Segmentation

Identify:

- OT network
- IT network
- Engineering access
- External connections (internet, cloud, remote access)
- Flat vs segmented parts

Explicitly point out **security weaknesses**, such as:

- Flat networks
- Unrestricted PLC access
- No separation between MES and PLCs
- Insecure services on PLCs or PCs

Phase 2 – Threat and Risk Analysis

4. Threat Modeling

Perform a threat analysis using:

- Typical **ICS attack scenarios**
- Realistic attacker profiles (student, insider, external attacker)

Consider:

- PLC manipulation
- Denial of service
- Unauthorized device access
- Malware infection via Engineering PC

- Data manipulation via MES/Webshop

Method suggestion:
STRIDE or simplified IEC 62443 threat categories

---

5. Risk Assessment

For each identified threat:

- Likelihood
- Impact on safety, production, education
- Overall risk score

Deliverable: Risk matrix with prioritization

Phase 3 – Secure Architecture Design (TOBE)

6. Security Requirements

Translate risks into **concrete security requirements**, such as:

- Network segmentation
- Controlled remote access
- Authentication on industrial protocols
- Logging and monitoring
- Backup and recovery
- Secure engineering access

Link each requirement explicitly to a **standard or regulation**.

---

7. Network Redesign

Design a **layered network architecture**, including:

- OT zones (PLC, I/O, robotics)
- Cell/area zones
- Industrial DMZ
- IT zone (MES, databases, Webshop)
- External zone (internet/cloud)

Must include:

- VLAN segmentation
- Firewall placement
- Restricted routing
- Justified protocol paths

Deliverables:

- **New logical network diagram**
- **Zone & conduit diagram (IEC 62443 style)**

---

8. Protocol Hardening

Explain how you secure:

- **Profinet** (physical separation, no routing, device whitelisting)
- **OPC UA** (certificates, encryption, user roles)
- **MQTT** (TLS, broker placement, authentication)
- Web interfaces (HTTPS, rolebased access)

Phase 4 – Hardware and Configuration Proposal

9. Security Hardware

Propose **realistic industrial hardware**, e.g.:

- Industrial firewall(s)
- Managed industrial switches
- Remote access gateway
- Separate engineering station

For each device:

- Function
- Network placement
- Justification

---

10. Organizational and Procedural Measures

Describe:

- User roles (operator, engineer, admin)
- Access rules
- Update strategy
- Backup strategy
- Incident response (educational level)

Regulations and Standards to Cover

Your design **must explicitly reference** relevant parts of:

- **IEC 62443 (11, 21, 33)** – Industrial Automation & Control Systems Security
- **ISO/IEC 27001** (context & principles)
- **NIS2 Directive (EU)** – highlevel industrial resilience
- **DefenseinDepth principle**
- **Least Privilege & Zero Trust (industrial interpretation)**

Full compliance is **not required**, but **alignment and motivation are mandatory**.